IT GOVERNANCE

# IT Governance COSO

## Kerangka Pengendalian Internal untuk Organisasi yang Lebih Terstruktur

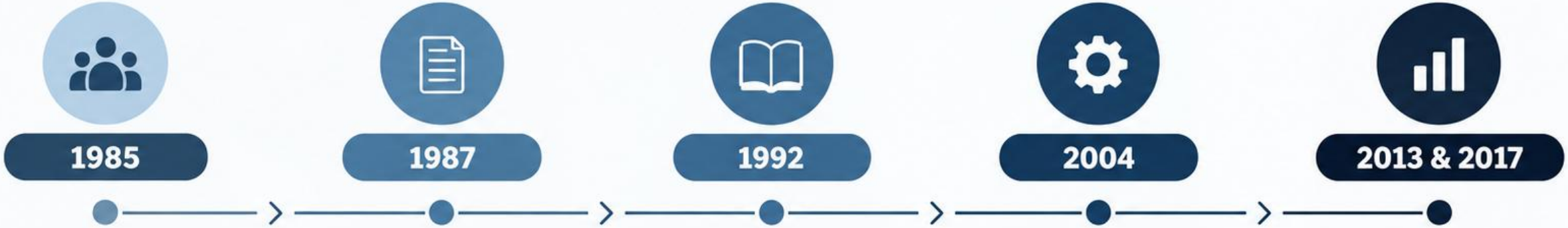



**Disusun oleh:**

| | | |
|---|---|---|
| 01 | Deny Dermawan | 1124160250 |
| 02 | Ahmad Ilyas | 1125170130 |
| 03 | Ilham Budi Handika | 1124160152 |
| 04 | Muhammad ilham Muttaqim | 1124160073 |
| 05 | Daffa Dermawan | 1124160177 |
| 06 | Aryan Firmansyah | 1124160175 |
| 07 | Rico adi Pratama | 1124160054 |

# 01 Sejarah dan Pembentukan COSO

Timeline perkembangan awal COSO




### COSO dibentuk

COSO (Committee *of* Sponsoring Organizations of the Treadway Commission) dibentuk untuk mensponsori komisi nasional yang menyelidiki faktor penyebab pelaporan keuangan yang curang *(fraudulent financial reporting)*.

### Rekomendasi awal

*National Commission on Fraudulent Financial Reporting* menerbitkan laporan yang memuat rekomendasi untuk memperbaiki pengawasan dan pengendalian internal di organisasi.

### Internal Control Framework

COSO menerbitkan *Internal Control—Integrated Framework* sebagai panduan untuk merancang, menerapkan, dan mengevaluasi pengendalian internal organisasi.

### Enterprise Risk Management

COSO menerbitkan *Enterprise Risk Management—Integrated Framework* (ERM) untuk memperluas fokus pada pengelolaan risiko perusahaan.

### Pembaruan framework

*Framework* Internal *Control* diperbarui pada 2013 dengan penekanan pada 17 prinsip, sedangkan *framework* ERM diperbarui pada 2017 dengan fokus pada integrasi risiko dengan strategi, kinerja, dan penciptaan nilai.

**Sumber:** COSO. (n.d.). *About Us; Internal Control—Integrated Framework; Enterprise Risk Management—Integrated Framework.*

02

# Perkembangan Framework COSO

Evolusi pengendalian internal dan manajemen risiko

## Internal Control (IC) Framework

Berfokus pada perancangan, penerapan, dan evaluasi sistem pengendalian internal untuk membantu organisasi mencapai tujuan.

### 1992

Kerangka pengendalian internal pertama (*Internal Control—Integrated Framework*)

→

### 2013

Pembaruan menjadi 5 komponen dan 17 prinsip dengan penekanan pada efektivitas pengendalian internal.

## Enterprise Risk Management (ERM) Framework

Memperluas fokus COSO dengan mengintegrasikan manajemen risiko ke dalam strategi, penetapan tujuan, dan kinerja organisasi.

### 2004

Kerangka manajemen risiko perusahaan (*Enterprise Risk Management—Integrated Framework*).

→

### 2017

Pembaruan dengan fokus pada integrasi risiko dengan strategi, penetapan tujuan, kinerja, dan penciptaan nilai.

**Pesan Utama** | COSO berkembang dari kerangka pengendalian internal menjadi pendekatan yang juga membantu organisasi mengelola risiko dan menghubungkannya dengan strategi serta kinerja.

**Sumber:** COSO. (2013). *Internal Control—Integrated Framework; COSO.* (2017). *Enterprise Risk Management—Integrating with Strategy and Performance.*

# 03 Latar Belakang COSO

Mengapa kerangka pengendalian internal dibutuhkan?

**Permasalahan utama**

Organisasi menghadapi risiko kecurangan, kelemahan pengawasan, dan pengendalian internal yang tidak berjalan secara efektif.

## Faktor yang mendorong lahirnya COSO

**Kecurangan pelaporan keuangan**

Kasus pelaporan keuangan yang tidak andal mendorong kebutuhan pengawasan dan pengendalian yang lebih baik.

**Pengawasan yang lemah**

Kontrol yang tidak memadai dapat membuat penyimpangan, kesalahan, atau kecurangan sulit dideteksi.

**Risiko organisasi**

Organisasi menghadapi berbagai risiko yang dapat memengaruhi pencapaian tujuan, sehingga membutuhkan pendekatan sistematis untuk mengidentifikasi dan mengendalikannya.

**Standar pengendalian**

Diperlukan kerangka acuan yang dapat membantu organisasi dalam merancang, menerapkan, dan menilai efektivitas pengendalian internal secara konsisten.

**Tujuan pembentukan kerangka**

Membantu organisasi membangun pengendalian internal yang lebih terstruktur, konsisten, dan dapat dievaluasi.

**Sumber:** COSO. (n.d.). *About Us; Internal Control—Integrated Framework (2013).*

04

# Konsep Dasar COSO

Kerangka pengendalian internal organisasi

## Pengertian

COSO (*Committee of Sponsoring Organizations of the Treadway Commission*) adalah organisasi yang menerbitkan kerangka kerja untuk membantuı organisasi merancang, menerapkan, dan mengevaluasi pengendalian internal.

## Tiga tujuan utama pengendalian internal menurut COSO

01

### Operasional

Mendukung efektivitas dan efisiensi kegiatan organisasi.

02

### Pelaporan

Menghasilkan pelaporan yang andal dan dapat dipercaya.

03

### Kepatuhan

Memastikan ketaatan terhadap hukum dan peraturan yang berlaku.

## Kaitan dengan Tata Kelola TI

Prinsip pengendalian internal COSO dapat diterapkan dalam pengelolaan teknologi informasi, seperti pengelolaan risiko TI, kontrol akses, keamanan data, dan pemantauan sistem.



**Sumber:** COSO. (2013). *Internal Control—Integrated Framework.*

05

# Tujuan dan Manfaat COSO

Nilai yang diperoleh dari penerapan COSO

Penerapan COSO memberikan berbagai **manfaat** bagi organisasi, terutama dalam meningkatkan efektivitas pengendalian internal, mengelola risiko, dan mendukung pencapaian tujuan organisasi.



*Kontrol yang baik, membangun organisasi yang lebih kuat.*

**01 Pengurangan Risiko**

Membantu mengidentifikasi, menilai, dan mengelola risiko yang dapat menghambat pencapaian tujuan organisasi.

**02 Penguatan Pengawasan**

Meningkatkan efektivitas pemantauan dan evaluasi terhadap proses serta kepatuhan.

**03 Peningkatan Akuntabilitas**

Memperjelas tanggung jawab dan memperkuat transparansi dalam pengelolaan organisasi.

**04 Dukungan terhadap Pencapaian Tujuan**

Memastikan organisasi dapat mencapai tujuan operasional, pelaporan, dan kepatuhan secara lebih efektif dan efisien.

**Sumber:** COSO. (2013). *Internal Control—Integrated Framework.*

06

# Arsitektur COSO untuk Tata Kelola TI

## Lima komponen pengendalian internal




### 01 Control Environment

Mencakup integritas, nilai etika, struktur organisasi, dan budaya pengendalian dalam organisasi.

### 02 Risk Assessment

Proses mengidentifikasi, menganalisis, dan menilai risiko yang dapat mempengaruhi pencapaian tujuan organisasi.

### 03 Control Activities

Kebijakan dan prosedur yang diterapkan untuk memastikan risiko dikendalikan secara efektif.

### 04 Information & Communication

Penyediaan dan pertukaran informasi yang relevan dan tepat waktu kepada pihak internal dan eksternal.

### 05 Monitoring Activities

Aktivitas pemantauan yang dilakukan secara berkelanjutan atau berkala untuk menilai efektivitas pengendalian internal dan melakukan tindakan perbaikan jika diperlukan.

### Penerapan dalam lingkungan TI

Kelima komponen COSO dapat digunakan untuk membantu mengendalikan akses sistem, menilai risiko keamanan data, menerapkan prosedur dan kontrol TI, menyampaikan informasi, serta mengevaluasi efektivitas kontrol TI.

**Sumber:** COSO. (2013). *Internal Control—Integrated Framework.*

07

# Cara Kerja COSO

Alur penerapan pengendalian internal dalam lingkungan TI

Proses berkelanjutan dan saling terhubung

**01 Menetapkan Tujuan**
Menentukan tujuan organisasi yang mencakup aspek operasional, pelaporan, dan kepatuhan, termasuk tujuan sistem TI.

↓

**02 Mengidentifikasi dan Menilai Risiko**
Mengidentifikasi risiko yang dapat mempengaruhi pencapaian tujuan, kemudian menganalisis dan menilai tingkat risikonya.

↓

**03 Menerapkan Aktivitas Pengendalian**
Merancang dan menerapkan kontrol yang tepat untuk mengurangi risiko, seperti pembatasan akses, autentikasi, pencadangan, dan persetujuan perubahan sistem.

↓

**04 Menyampaikan Informasi dan Komunikasi**
Menyediakan dan menyampaikan informasi yang relevan, termasuk kebijakan, prosedur, laporan risiko, dan insiden kepada pihak internal dan eksternal yang terkait.

↓

**05 Memantau dan Mengevaluasi**
Melakukan pemantauan secara berkelanjutan untuk memastikan kontrol berjalan efektif dan melakukan perbaikan jika ditemukan kelemahan.

## Contoh penerapan dalam lingkungan TI

**Tujuan TI**
Menyediakan sistem yang andal, aman, dan sesuai regulasi.

**Contoh risiko**
Akses tidak sah, kebocoran data, kehilangan data, gangguan sistem, atau kesalahan konfigurasi.

**Contoh kontrol**
Manajemen akses, enkripsi, pencadangan data, pemisahan tugas, dan manajemen perubahan.

**Contoh informasi**
Laporan insiden, hasil audit, kebijakan keamanan, dan komunikasi risiko.

**Contoh pemantauan**
Audit log, review akses, evaluasi kontrol, dan tindak lanjut temuan.

**Catatan penting**
Diagram ini merupakan penyederhanaan alur penerapan COSO untuk pembelajaran. Dalam praktiknya, kelima komponen saling berhubungan dan dapat berjalan secara bersamaan serta berkelanjutan.

**Sumber:** COSO. (2013). *Internal Control—Integrated Framework.*

08

# 17 Prinsip COSO

Rincian prinsip pada setiap komponen pengendalian internal

## Control Environment

1. Integritas dan nilai etika
2. Pengawasan independen
3. Struktur organisasi, wewenang, dan tanggung jawab
4. Kompetensi dan pengembangan SDM
5. Akuntabilitas atas pengendalian internal

## Risk Assessment

6. Menetapkan tujuan yang jelas
7. Mengidentifikasi dan menganalisis risiko
8. Menilai risiko kecurangan (*fraud*)
9. Mengidentifikasi dan menilai perubahan signifikan

## Control Activities

10. Memilih dan mengembangkan aktivitas pengendalian
11. **Mengembangkan kontrol umum atas teknologi (informasi dan sistem TI)**
12. Menerapkan kontrol melalui kebijakan dan prosedur

## Information & Communication

13. Menggunakan informasi yang relevan dan berkualitas
14. Melakukan komunikasi internal
15. Melakukan komunikasi eksternal

## Monitoring Activities

16. Melakukan evaluasi berkelanjutan atau terpisah
17. Mengevaluasi dan mengomunikasikan kelemahan pengendalian internal

**Sumber:** COSO. (2013). *Internal Control—Integrated Framework.*

09

# Jenis Organisasi yang Dapat Menerapkan COSO

Berbagai sektor dan jenis organisasi

01

### Perusahaan Energi

Seperti perusahaan minyak dan gas, termasuk kegiatan distribusi dan penjualan energi. Fokus pada pengendalian operasional, risiko, dan kepatuhan regulasi.



02

### Manufaktur

Pengendalian proses produksi, persediaan, aset, kualitas, dan rantai pasok untuk mengurangi risiko operasional.



03

### Perdagangan & Jasa

Seperti ritel, e-commerce, logistik, dan perusahaan jasa lainnya. Fokus pada pengendalian penjualan, persediaan, layanan pelanggan, dan pelaporan keuangan.



04

### Organisasi Publik

Instansi pemerintah dan badan layanan publik. Fokus pada akuntabilitas, pengelolaan anggaran, kepatuhan, dan transparansi.



05

### Organisasi Nirlaba

Seperti yayasan, lembaga sosial, dan organisasi keagamaan. Fokus pada pengelolaan dana, aset, program, dan akuntabilitas kepada pemangku kepentingan.



06

### Perusahaan Teknologi & IT

Pengendalian akses sistem, keamanan data, pengembangan aplikasi, infrastruktur TI, dan keberlangsungan layanan untuk mengurangi risiko teknologi.



### COSO bersifat fleksibel

Dapat diterapkan di berbagai jenis organisasi dan disesuaikan dengan ukuran, sektor, dan kompleksitas organisasi, baik di sektor swasta, publik, maupun nirlaba, termasuk dalam tata kelola TI.

**Sumber:** COSO. (2013). *Internal Control—Integrated Framework.*

10

# Kelebihan dan Kekurangan COSO

Evaluasi penerapan pengendalian internal

## Kelebihan COSO

Memberikan kerangka yang kuat, terstruktur, dan fleksibel untuk mendukung pencapaian tujuan organisasi.

01 **Kerangka yang terstruktur**
Lima komponen dan 17 prinsip membantu organisasi menata pengendalian internal secara sistematis.

02 **Mendukung manajemen risiko**
Membantu identifikasi dan penilaian risiko sehingga pengendalian dapat lebih tepat sasaran.

03 **Meningkatkan akuntabilitas**
Mendorong transparansi, kepatuhan, dan tata kelola yang lebih baik.

04 **Fleksibel dan dapat disesuaikan**
Dapat diterapkan di berbagai jenis organisasi, ukuran, dan sektor.

## Kekurangan COSO

Penerapan COSO memiliki beberapa tantangan yang perlu dipertimbangkan oleh organisasi.

01 **Membutuhkan sumber daya yang cukup**
Penerapan memerlukan waktu, biaya, dan tenaga kerja yang memadai, terutama untuk organisasi dengan skala besar.

02 **Bergantung pada faktor manusia**
Kesalahan manusia, kurangnya integritas, atau kolusi tetap dapat terjadi meskipun pengendalian sudah dirancang dengan baik.

03 **Perlu penyesuaian dengan organisasi**
Tidak ada pendekatan yang sama untuk semua organisasi. Kontrol harus disesuaikan dengan ukuran, kompleksitas, dan industri.

04 **Implementasi bisa kompleks**
Membutuhkan perencanaan, dokumentasi, dan perubahan proses yang dapat memakan waktu.

**Inti evaluasi**
COSO memberikan banyak manfaat dalam memperkuat pengendalian internal, tetapi bukan jaminan bahwa seluruh risiko dapat dihilangkan. Keberhasilannya sangat bergantung pada komitmen, sumber daya, dan penerapan yang tepat.

**Sumber:** COSO. (2013). *Internal Control—Integrated Framework.*

11

# Tantangan Implementasi COSO

Hambatan utama dalam penerapan pengendalian internal

## 01 Komitmen Manajemen

- Dukungan dan keterlibatan aktif pimpinan
- Kebijakan dan pengawasan yang konsisten
- Budaya kontrol dari atas ke bawah



## 02 Keterbatasan Sumber Daya

- Keterbatasan anggaran
- Waktu dan tenaga ahli
- Kebutuhan pelatihan dan kompetensi



## 03 Budaya dan Proses Kerja

- Resistensi terhadap perubahan
- Kurangnya pemahaman kontrol
- Proses kerja belum terdokumentasi dengan baik



## 04 Adaptasi Teknologi

- Ancaman keamanan siber
- Perubahan dan pengembangan sistem
- Kompleksitas infrastruktur TI



**Kunci keberhasilan**

Penerapan COSO memerlukan komitmen, sumber daya yang memadai, adaptasi terhadap perubahan, dan pemantauan berkelanjutan.

**Sumber:** COSO. (2013). *Internal Control—Integrated Framework.*

# 12 Review Jurnal 1

## Penerapan Sistem Pengendalian Internal dengan COSO Integrated Framework

Fitriah Kesuma Jelita dan Novita (2022)

https://journal.uin-alauddin.ac.id/index.php/assets/article/view/33312

Jurnal:
**ASSETS**
Vol. 12, No. 2, 2022
Hal. 195–210

## 01 Latar Belakang & Tujuan

**Latar Belakang**

SPBU PT Marka Sakti (berdiri sejak 2003) masih menghadapi hambatan dalam pengendalian internal, seperti keterbatasan SDM, rangkap tugas, dan pengawasan yang belum memadai.

**Tujuan Penelitian**

Mengetahui penerapan sistem pengendalian internal pada SPBU PT Marka Sakti dan mengevaluasinya berdasarkan COSO Integrated Framework.

## 02 Hasil Penelitian

1. Sistem pengendalian internal belum tersusun secara formal dan masih terdapat ketidaksesuaian dengan COSO.
2. Ditemukan belum adanya struktur organisasi yang memadai serta penilaian risiko, pemantauan, dan dokumentasi yang belum terstruktur.

## 03 Subjek Penelitian

SPBU PT Marka Sakti di Pelayang Raya, Kota Sungai Penuh, Kerinci, Provinsi Jambi.

## 04 Evaluasi & Kesimpulan

**Kekuatan Penelitian**

Menggunakan lima komponen dan 17 prinsip COSO sebagai kerangka evaluasi yang terstruktur.

**Kelemahan Penelitian**

Hanya berfokus pada satu objek (satu SPBU) sehingga temuan tidak dapat digeneralisasi ke perusahaan lain.

**Kesimpulan**

Sistem pengendalian internal PT Marka Sakti masih kurang efektif dan perlu perbaikan pada struktur, penilaian risiko, serta prosedur pemantauan dan dokumentasi.

# 13 Review Jurnal 2

**Analisis Penerapan COSO Framework terhadap Keberhasilan Sistem Pengendalian Internal Siklus Produksi PT. Yongjin Javasuka Garment Factory II**

Intan Kusdiana Safitri, Ade Budi Setiawan, dan Yoyok Priyo Hutomo (2025)

https://ejournal.kompetif.com/index.php/akuntansikompetif/article/view/2239

Jurnal:
**Jurnal Akuntansi Kompetif**
Vol. 8, No. 3, September 2025
Hal. 680–688

## 01 Latar Belakang & Tujuan

| | |
|---|---|
| **Latar Belakang** | Perusahaan garmen menghadapi masalah efisiensi produksi, kualitas produk, dan ketepatan waktu, seperti target produksi tidak tercapai, produk cacat melebihi toleransi, dan lembur. |
| **Tujuan Penelitian** | Menganalisis pengaruh penerapan COSO Framework terhadap keberhasilan sistem pengendalian internal pada siklus produksi PT. Yongjin Javasuka Garment Factory II. |

## 02 Hasil Penelitian

1. Kelima komponen COSO berpengaruh signifikan secara parsial maupun simultan terhadap keberhasilan pengendalian internal siklus produksi.

## 03 Subjek Penelitian

| | |
|---|---|
| **Responden** | 100 karyawan bagian produksi PT. Yongjin Javasuka Garment Factory II yang terlibat langsung dalam proses pengendalian siklus produksi. |

## 04 Evaluasi & Kesimpulan

**Kekuatan Penelitian**
Melibatkan 100 responden dan menggunakan analisis statistik yang lengkap.

**Kelemahan Penelitian**
Sampel hanya berasal dari satu perusahaan sehingga generalisasi terbatas.

**Kesimpulan**
Penerapan COSO berpengaruh signifikan terhadap keberhasilan pengendalian internal siklus produksi.

# 14 Kesimpulan




**01** COSO merupakan kerangka pengendalian internal yang membantu organisasi mencapai **tujuan operasional, pelaporan, dan kepatuhan** melalui **lima komponen dan 17 prinsip** yang saling berkaitan.

**02** Dalam konteks tata kelola TI, prinsip COSO dapat diterapkan untuk mendukung **pengendalian akses, keamanan data, pengelolaan risiko teknologi**, serta **pemantauan sistem informasi**.

**03** Dua penelitian yang dibahas menunjukkan bahwa COSO dapat diterapkan dalam pengendalian internal pada berbagai konteks organisasi, yaitu **SPBU PT Marka Sakti** dan **PT Yongjin Javasuka Garment Factory II** di **sektor manufaktur**. Hasil penelitian tersebut menunjukkan relevansi COSO dalam mendukung pengendalian internal sesuai dengan kebutuhan organisasi.

**Intinya: COSO dapat menjadi landasan pengendalian internal yang terstruktur dan fleksibel,** serta menjadi referensi dalam mendukung tata kelola TI sesuai dengan risiko dan kebutuhan masing-masing organisasi.

**Sumber:** COSO. (2013). *Internal Control—Integrated Framework.*

# TERIMA KASIH

# SESI PERTANYAAN :

1. Bagaimana manajemen memastikan bahwa personil TI memahami sanksi atas pelanggaran kebijakan keamanan data?
2. Bagaimana ERM mampu meningkatkan keunggulan bisnis perusahaan
3. Bagaimana strategi mitigasi resiko kegalan investasi IT yg dapat merugikan perusahaan
4. Jelaskan mengapa tatakelola TI perlu dilakukan perlindubgan terhadap resiko yg muncul khususnya cyber sekurity
5. Bagaimana risiko terkait integritas dan kerahasiaan data dievaluasi dalam siklus hidup pengembangan sistem (SDLC)
6. Jelaskan 4 komponen COSO dalam mendukung tatakelola IT dalam menunjang jalannya bisnis berjalan dgn baik
7. Bagaimana manajemen mengkomunikasikan dampak risiko teknologi kepada pemegang saham atau investor
8. Jelaskan 7 prinsip COSO dalam meningkatkan pengendalian internal dalam tata kelola IT
9. Bagaimana cara mengevaluasi dan melakukan komunikasi terkait kelemahan pendalian internal
10. Jelaskan 3 tantangan utama dalam implementasi COSO pada perusahaan untuk mendukung tata kelola IT yg baik

# JAWABAN

- 1. Manajemen dapat memastikan personel TI memahami sanksi dengan cara memberikan sosialisasi mengenai kebijakan keamanan data, mengadakan pelatihan keamanan secara berkala, serta membuat aturan tertulis yang menjelaskan jenis pelanggaran dan sanksinyaSelain itu, setiap personel TI harus memahami tanggung jawabnya dalam menjaga keamanan data. Manajemen juga perlu menerapkan sanksi secara konsisten sesuai tingkat pelanggaran, misalnya teguran tertulis, pembatasan akses sistem, hingga tindakan disipliner sesuai peraturan perusahaan. Contoh: Jika seorang karyawan membagikan kata sandi sistem perusahaan kepada orang lain, perusahaan harus menjelaskan bahwa tindakan tersebut melanggar kebijakan keamanan dan dapat dikenai sanksi.
- 2. ERM (Enterprise Risk Management) adalah pendekatan untuk mengidentifikasi, menilai, dan mengelola risiko yang dapat memengaruhi pencapaian tujuan perusahaan. ERM dapat meningkatkan keunggulan bisnis karena membantu perusahaan mengantisipasi masalah sebelum terjadi, mengurangi potensi kerugian, dan mengambil keputusan bisnis dengan lebih tepat. Dengan pengelolaan risiko yang baik, perusahaan juga dapat memanfaatkan peluang bisnis dan meningkatkan kepercayaan pelanggan maupun investor. Contoh: Perusahaan yang menggunakan ERM dapat mengidentifikasi risiko serangan siber sejak awal, kemudian meningkatkan keamanan sistem untuk melindungi data pelanggan. Dengan begitu, perusahaan dapat mengurangi potensi kerugian dan menjaga kepercayaan pelanggan sehingga mampu bersaing lebih baik dengan perusahaan lain.
- 3. Menurut saya, kuncinya ada 4 hal. Pertama, sebelum investasi harus jelas dulu business case-nya sesuai nggak sama tujuan bisnis dan worth it nggak biayanya. Kedua, jalannya bertahap, pilot dulu, jadi kalau gagal kerugiannya kecil. Ketiga, kontrak vendor harus jelas, ada SLA dan exit strategy biar nggak kejebak. Terakhir, user-nya dilibatkan dan dilatih, karena banyak proyek gagal bukan karena teknologinya jelek tapi karena nggak ada yang mau pakai. Terus dimonitor berkala, kalau udah melenceng berani cut loss.
- 4. Karena sekarang TI itu inti bisnis, dan data itu aset paling berharga. Kalau kena serangan siber, perusahaan bisa rugi, kena denda, reputasi hancur, pelanggan kabur. Tanpa tata kelola, keamanan cuma jadi urusan teknisi doang. Tata kelola bikin keamanan jadi tanggung jawab manajemen ada kebijakan, ada kontrol, ada monitoring. Jadi perusahaan bisa cegah serangan, cepat pulih kalau kena, dan tetap dipercaya pelanggan sama investor.

# JAWABAN

- 5. Risikonya dicek dari awal pembuatan sistem sampai sistemnya dipakai. Caranya dengan membatasi siapa aja yang bisa akses data, mengamankan data, dan mengetes sistem supaya data nggak bocor atau diubah sembarangan
- 6. Lingkungan Pengendalian: Membuat aturan dan tanggung jawab yang jelas bagi karyawan.
  - Penilaian Risiko: Mengidentifikasi risiko yang bisa mengganggu sistem IT.
  - Aktivitas Pengendalian: Melakukan tindakan pencegahan, seperti membatasi akses sistem.
  - Pemantauan: Memeriksa secara rutin apakah sistem dan pengendaliannya berjalan dengan baik.
- 7. Manajemen bisa menyampaikan informasi risiko teknologi melalui laporan tahunan, rapat pemegang saham, atau laporan risiko. Informasi yang disampaikan meliputi potensi kerugian, dampak terhadap bisnis, dan langkah yang dilakukan untuk mengatasi risiko tersebut. Dengan begitu, investor bisa memahami kondisi perusahaan dan mengambil keputusan yang lebih tepat.
- 8. Jawaban :
  - 1. Menjaga integritas dan etika -> Perusahaan harus memastikan karyawan bekerja dengan jujur dan mengikuti aturan yang berlaku. Contohnya, personel TI tidak boleh menyalahgunakan akses untuk melihat atau mengambil data rahasia perusahaan.
  - 2. Membagi tanggung jawab dengan jelas -> Setiap karyawan harus memiliki tugas dan wewenang yang jelas supaya tidak terjadi penyalahgunaan kekuasaan. Contohnya, orang yang mengelola sistem tidak boleh sembarangan menyetujui perubahan sistemnya sendiri tanpa pemeriksaan.
  - 3. Mengidentifikasi dan menilai Risiko -> Perusahaan harus mengetahui risiko yang mungkin terjadi pada sistem TI, seperti kebocoran data, serangan siber, atau kerusakan server. Dengan begitu, perusahaan bisa menyiapkan langkah pencegahan sebelum masalah terjadi.
  - 4. Menerapkan aktivitas pengendalian -> Perusahaan perlu membuat aturan dan prosedur untuk mengurangi risiko. Contohnya, menggunakan kata sandi yang kuat, autentikasi dua faktor, membatasi hak akses, dan melakukan pencadangan data secara rutin.
  - 5. Mengendalikan penggunaan teknologi -> Perusahaan harus memastikan teknologi yang digunakan aman dan hanya bisa diakses oleh pihak yang berwenang. Misalnya, membatasi akses berdasarkan jabatan, memperbarui sistem keamanan, dan mencatat aktivitas pengguna untuk mendeteksi aktivitas mencurigakan.
  - 6. Menyampaikan informasi dan komunikasi dengan baik -> Informasi tentang keamanan dan risiko TI harus disampaikan dengan jelas kepada pihak terkait. Contohnya, jika terjadi kebocoran data, tim TI harus segera melaporkannya kepada manajemen agar bisa segera ditangani.
  - 7. Melakukan pemantauan dan evaluasi -> Perusahaan harus rutin memeriksa apakah pengendalian internal sudah berjalan dengan baik. Misalnya, melakukan audit sistem, mengecek hak akses karyawan, dan memperbaiki kelemahan keamanan yang ditemukan.

# JAWABAN

- 9. Cara mengevaluasi kelemahan pengendalian internal adalah dengan melakukan pemeriksaan terhadap sistem dan prosedur perusahaan untuk mengetahui gimana pengendalian yang diterapkan sudah berjalan dengan baik atau belum. Evaluasi yg bisa dilakukan misalnya melalui audit internal, pemeriksaan dokumen, wawancara dengan karyawan, serta pengujian terhadap sistem informasi yang digunakan perusahaan.
- 10. Tiga tantangan utama dalam implementasi COSO pada perusahaan adalah sebagai berikut. :
  - 1. Kurangnya pemahaman dan kesadaran karyawan

    Akibatnya, prosedur pengendalian sering dianggap sebagai beban tambahan, bukan sebagai upaya untuk mengurangi risiko.
  - 2. Biaya dan keterbatasan sumber daya

    Untuk mengatasinya, perusahaan perlu menentukan prioritas berdasarkan tingkat risiko dan menggunakan sumber daya secara efisien agar pengendalian IT dapat berjalan dengan baik.
  - 3. Perkembangan teknologi dan risiko keamanan informasi

    Perkembangan teknologi yang cepat menimbulkan berbagai risiko baru, seperti serangan siber, kebocoran data, penyalahgunaan hak akses, dan kegagalan sistem.